GOVERNANCE · RISK · COMPLIANCE

The Norvela GRC Lab

A complete, self-hosted environment for learning governance, risk and compliance by assessing one fictional EU payment institution end to end.

PROGRAMME	12 weeks · 8 phases (P0–P7) · ~8 h/week
SUBJECT	Norvela Pay, S.A. (Lisboa)
SCOPE	DORA · NIS2/RJC · GDPR · PCI DSS · ISO 27001 · SOC 2 · EU AI Act
AUTHOR	Bilal Ahmad Kamal
SOURCE	github.com/BAKROOT/norvela-grc-lab
VERIFIED	September 2026

Norvela Pay, its people, its vendors, its licence number, its incident and its supervisory correspondence are entirely fictional. Real tools and real regulations are named accurately; the company they are applied to is not real. Regulatory dates were current as of September 2026. Verify before citing.

Contents

01 **Overview**
What the lab is and why it is shaped this way

02 **The Programme**
Eight phases, twelve weeks, with deliverables and proof gates

03 **Company Dossier: Norvela Pay**
Your assessment target: governance, estate, data, third parties

04 **Incident Pack NOR-2026-0908**
A live incident with ten timed decision points

05 **Lab Setup**
Building the environment in six parts, about three hours

06 **Scenario Evidence**
Artefacts the dossier and incident pack refer to

07 **Interview Question Bank**
120 questions across six categories, with what a strong answer contains

08 **Timed Case Studies**
Six cases in the formats real GRC interviews use

— **Findings Key**
Supplied as a separate sealed document. Do not open until Phase 3.

Overview

You assess **Norvela Pay, S.A.**, a fictional authorised payment institution in Lisbon with 340 staff, four legal entities, 20 third parties and **46 planted findings**. The work covers everything a GRC analyst does on a real engagement: risk assessment, scoping, control testing, third-party risk, a DORA Register of Information, a live incident, reporting to the board, and turning it all into interview material. It runs for twelve weeks at about eight hours a week.

Every phase ends in an **artefact a stranger could read**, so by the end you have a portfolio to show: a Statement of Applicability, a Register of Information, an incident classification memo and a quantified investment case.

Start here

1. `02-stack/SETUP.md`: build the lab. One evening.
2. `01-scenario/00-COMPANY-DOSSIER.md`: read up on the company you are assessing.
3. `CURRICULUM.md`: the phases. Work them in order.

Do not open the Findings Key (a separate document) until Phase 3 is complete.

Fiction notice

Norvela Pay, its people, its vendors, its licence number, its incident and its supervisory correspondence are entirely fictional. Real tools and real regulations are named accurately; the company they are applied to is not real. Regulatory dates were current as of September 2026. Verify before citing.

Why it's built this way

One company, not many exercises. Real GRC work builds on itself: your scoping decision in week 4 constrains your control testing in week 6. Isolated exercises never teach that. Living inside one organisation for twelve weeks does.

Deliberately broken, deliberately realistic. Norvela is not a disaster zone. It is a normal, competent, fast-growing company that has built up the usual debt, half-finished processes and gaps between teams. Its Poland entity runs a separate HR system, and that is not an exotic failure. It is *the* most common root cause of leaver-process gaps in firms with several legal entities.

Multi-regulation on purpose. DORA, NIS2, GDPR, PCI DSS, ISO 27001, SOC 2 and the EU AI Act all apply at once. Handling that overlap is the actual job. One MFA control is evidence for six regimes, but a control that maps to a requirement does not satisfy every regime equally.

Artefacts, not notes. Every phase ends with something a stranger could read. Reading gives you the feeling of learning. Writing produces the thing.

Regulatory currency

The dates and framework states in this lab were checked in **September 2026**:

- **DORA** (Reg. EU 2022/2554) has applied since 17 January 2025. The Register of Information is submitted once a year through national competent authorities.
- **NIS2 in Portugal**: Decreto-Lei 125/2025 (Regime Jurídico da Cibersegurança) has been in force since 3 April 2026. CNCS is the lead authority and CERT.PT the national CSIRT.
- **ISO/IEC 27001**: the 2013→2022 transition closed on 31 October 2025. Amendment 1:2024 adds a climate-change determination at Clause 4.1.
- **EU AI Act**: Art. 50 transparency obligations apply from 2 August 2026. The Digital Omnibus (Reg. EU 2026/1744) moved Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028.

Check a date before you cite it. Regulation moves faster than any lab, and the habit of checking instead of reciting is part of the professional skill this lab teaches.

The Programme

Seven phases. Each has a **mission**, **steps**, a **deliverable**, and a **proof gate** you must pass before moving on. The proof gate is the point: it is how you know you actually learned it rather than read it.

Pace assumes ~8 hours a week. Compress to 6 weeks at 16 h/wk if you want. Do not skip phases. Phase 3 makes no sense without Phase 2's scoping work, which is precisely the mistake most people make in real jobs.

The rule that makes this work: every phase ends with a written artefact you could hand to a stranger. Not notes. Not a checklist you ticked. A document with your name on it that would survive being read by an auditor. Reading produces the feeling of learning. Writing produces the thing.

Phase 0 — Set up and orient (Week 1, ~6 h)

Mission. Get the lab running and read yourself into the company the way a new CISO would in their first three days.

Steps

1. Work through `02-stack/SETUP.md`. Stop when `healthcheck.sh` is green for CISO Assistant, Juice Shop, OpenSearch and Mailpit. Skip GVM for now.
2. Read `01-scenario/00-COMPANY-DOSSIER.md` once, fast, without taking notes.
3. Read it again, slowly, with a blank page. Write down every single thing that makes you uncomfortable. Do not organise it. Just list. You should reach 40+ items.
4. Now organise that list into three columns: **things that are broken**, **things I don't know yet**, **things I would need to ask someone**. The third column is the most valuable and the one beginners leave empty.
5. Load ISO 27001:2022, DORA and GDPR libraries into CISO Assistant. Create the `Norvela Pay` domain and the five perimeters.

Deliverable — `Day 3 Observations Memo`, 2 pages max. Written to the CEO. What you found, what worries you most, what you need from her in the next 30 days. No jargon. No framework names in the first paragraph.

Proof gate. Give the memo to someone non-technical and ask them to tell you back what the top three problems are. If they can't, rewrite it. Executive communication is a testable skill and this is the test.

Phase 1 — Governance and risk foundations (Weeks 2–3, ~16 h)

Mission. Build the machinery that everything else hangs off: risk criteria, appetite, roles, and a register that is not embarrassing.

Steps

1. Open `03-workbooks/risk-register.xlsx`, sheet `INHERITED-REGISTER`. Write a critique. Find at least twelve structural defects. Some starters so you know the standard: risks stated as single nouns rather than cause-event-consequence; no defined scoring criteria so "High" is meaningless; departments as owners instead of named humans; "mitigation" stated as an aspiration ("AWS is reliable") rather than a control; no residual scoring; no link to assets or regulations; no review dates; one entry closed with no evidence of closure. Find the rest yourself.
2. Fill in `SCORING-CRITERIA`. The scales are drafted — challenge them. Are the financial impact bands right for a €61M-revenue firm? Defend your answer with a number (e.g. impact band 5 should be an amount that threatens capital adequacy or the licence, not an arbitrary round figure).
3. Complete `RISK-APPETITE`. The draft statements are derived from board behaviour in §10 of the dossier. Add at least two more and write the escalation path for each.
4. Rebuild the register in `RISK-REGISTER-V2`. Source material: the dossier's §4.3 technical facts, `assets.csv`, `vendors.csv`, `iam-users.csv`, and the incident pack. **Target 35–45 risks.**
5. Write the governance fix: RACI for the three lines, a Risk Committee charter that reflects reality, and a one-page paper on the acting-CISO conflict with a recommended resolution.

Deliverable. Completed workbook + governance pack (RACI, charter, conflict paper).

Proof gate. Pick your five highest risks. For each, say out loud, in under 60 seconds and without notes: what could happen, why it could happen here specifically, what it would cost, and what you would do about it first. Record yourself. Watch it back. This is literally the interview.

Phase 2 — Scoping and the Statement of Applicability (Week 4, ~8 h)

Mission. Decide what is in scope for what, and produce a defensible SoA. This is the phase people skip and the phase auditors attack.

Steps

1. **ISMS scope statement.** Which entities, which locations, which services, which assets? The Poland entity has production access — in or out? Justify. The sandbox environment — in or out? Justify. Write the scope statement in the form an auditor will read it, including exclusions and the reason for each.
2. **PCI DSS scope.** Draw the cardholder data environment. Where does PAN live? (Ledger, HSM, Datadog logs — the last one is the trap.) Which systems are connected-to or security-impacting? Decide SAQ type vs RoC and justify. The staging environment holding unmasked PANs blows your scope wide open — say so, and price the remediation against the cost of the expanded scope.
3. **DORA scope.** Identify the **critical or important functions**. This is a judgement call you will defend to a supervisor. Use the test: would disruption materially impair financial performance, soundness, or continuity of authorised services? Write the justification per function.

4. **NIS2/RJC scope.** Is Norvela an essential or important entity under Decreto-Lei 125/2025? Work through the sector and size tests. Then write the *lex specialis* analysis: where DORA displaces the RJC for a payment institution, and where the RJC still applies. Portugal's RJC entered into force 3 April 2026, with CNCS as the lead authority and CERT.PT as the national CSIRT — registration and incident duties run through them.
5. **AI Act scope.** Classify Sentinel and Flow. Note the timeline as it now stands: the Digital Omnibus (Reg. EU 2026/1744) moved Annex III high-risk obligations to **2 December 2027** and Annex I to **2 August 2028**, while Art. 50 transparency obligations applied from **2 August 2026**. Decide whether Flow is Annex III (creditworthiness) and whether Norvela is provider, deployer, or both. Argue it in writing.
6. **Build the SoA** in CISO Assistant against ISO 27001:2022 Annex A (93 controls, four themes: 37 organisational, 8 people, 14 physical, 34 technological). For every control: applicable or not, why, current implementation status, and the evidence reference. **Excluding a control requires a written justification — those are the ones the auditor reads first.** Include Amendment 1:2024: your Clause 4.1 context analysis must record a determination on whether climate change is a relevant issue.

Deliverable. Five scope statements + a complete SoA.

Proof gate. Have someone pick three controls at random from Annex A and ask you: applicable? why? what's the evidence? If you hesitate on more than one, your SoA is decoration.

Phase 3 — Control assessment and evidence (Weeks 5–6, ~16 h)

Mission. Stop asserting and start proving. This is where the lab stack earns its keep.

Steps

1. **Design vs operating effectiveness.** Learn the distinction cold: *design* asks whether the control, as built, would prevent or detect the risk; *operating effectiveness* asks whether it actually did, consistently, over a period. SOC 2 Type I tests design at a point in time; Type II tests operation over 3–12 months. Interviewers ask this constantly.
2. **Write test procedures** for 20 controls before testing anything. Each procedure: control objective, test steps, sample size and selection basis, evidence required, pass/fail criteria. Sampling matters — for a control that operates daily over 12 months, why 25 and not 5? Write the rationale.
3. **Test them.** - Access review: use `iam-users.csv`. There are eight planted problems (two leavers with live IAM, two unmanaged root accounts, a shared contractor account, a dormant admin service account, the breach-vector service account, an external auditor account with no expiry). Find all eight. Produce the review artefact: who reviewed, when, what was removed. - Vulnerability management: `vuln-findings.csv`. There is no SLA. Define one, then measure current performance against it. 38 criticals, every one of them over 180 days old. - Cloud configuration: run Prowler against your AWS account or LocalStack. Map every failed check to an Annex A control and a DORA article. - Host hardening: OpenSCAP against a VM. Attach `scan-report.html` as evidence. - Logging: ship something to OpenSearch and write a query that would detect the NOR-2026-0908 pattern (service account, unusual source IP, payout volume anomaly). A detection you can demonstrate beats a policy that says you detect.
4. **Build the evidence library.** One folder per control. Naming convention, collection date, collector, period covered, and — critically — whether it is design or operating evidence.

Deliverable. 20 tested controls with workpapers and an evidence library.

Proof gate. Hand your access review workpaper to someone and ask: could you re-perform this test from what's written here and get the same answer? That is the actual standard for audit documentation.

Phase 4 — Third-party risk and the DORA Register (Weeks 7–8, ~16 h)

Mission. The single most employable artefact in this lab.

Steps

1. Build a tiering model. Not "high/medium/low" — a model with criteria: does it support a critical or important function, does it process personal or cardholder data, is it substitutable, what is the concentration exposure?
2. Tier all 20 vendors in `vendors.csv`.
3. Run a full due-diligence assessment on the worst three. Sertã Systems is the deliberate horror: a two-person company with standing VPN access to the authoritative settlement ledger, a 2019 contract with no DORA clauses, no audit rights, no exit plan. Write the assessment, the risk acceptance or treatment recommendation, and the contract remediation asks.
4. **Build the Register of Information** in `03-workbooks/dora-register-of-information.xlsx`. Work the sheets in the order the HOW-TO tab gives. The function taxonomy comes first: you cannot populate anything until you have decided what is critical or important. Cite Art. 28(3) and the ITS (EU) 2024/2956 in your covering note.
5. Write the **data-quality statement**: every field you could not populate, why, who owns closing it, by when. This directly answers the Banco de Portugal letter of 2026-03-11 and is due 2026-11-30 in scenario time.
6. Concentration risk analysis: AWS supports 100% of production. Write the board paper on it — the options, the cost of each, and your recommendation. "Multi-cloud everything" is the wrong answer and you should be able to say why.

Deliverable. Completed RoI + data-quality statement + concentration paper + three due-diligence reports.

Proof gate. Explain to a non-specialist, in three minutes, what the Register of Information is for and why regulators wanted it. If you say "because DORA requires it," you have not understood it. (It exists so supervisors can see systemic concentration across the whole sector — which is how the first critical provider designations were made.)

Phase 5 — Incident, continuity, and the regulatory clock (Week 9, ~8 h)

Mission. Perform under time pressure with incomplete information.

Steps

1. Work `01-scenario/10-INCIDENT.md` **in real time**. Set a timer. Make each **[DECIDE]** call before reading on, and timestamp your decisions.
2. Produce all seven deliverables listed at the end of that pack.

3. Then go back and do the thing nobody does: **compare your T+11h classification to your T+2day classification** and write the note explaining why the first one was reasonable on the information available. Supervisors judge the process, not the hindsight.
4. Run the BIA Norvela never did. RTO/RPO per business service. Then check them against reality: the Ledger restore has never been successfully tested since a failed 2022 attempt. What is your *actual* RTO? It is not the number in the plan.
5. Write the DORA-aware incident response plan and the cloud-outage continuity plan the company lacks.

Deliverable. Full incident pack + BIA + revised IRP and BCP.

Proof gate. Have someone read you the incident timeline aloud, stopping at each decision point, and answer cold. No notes. That is the tabletop exercise and it is also how a panel interview for a risk role feels.

Phase 6 — Reporting, audit and the board (Week 10, ~8 h)

Mission. Make the work land with people who have 90 seconds.

Steps

1. **Internal audit.** Plan and perform an ISO 27001 internal audit of three Annex A themes. Audit programme, checklist, evidence, findings with nonconformity classification (major/minor/observation), and a CAPA plan.
2. **Management review.** Produce the Clause 9.3 management review input pack and minutes. This is the clause auditors find missing most often.
3. **Metrics.** Build a KRI/KPI set that a board would actually use. Rules: no more than 8; each must have a threshold; each must be automatically collectable; each must be one someone would act on. Kill any metric where the honest answer to "what would we do if this went red?" is "nothing."
4. **Board paper.** One page. The quarterly risk report. Top risks, movement since last quarter, appetite breaches, the ask.
5. **The customer questionnaire.** 214 questions, three weeks, €4.1M ARR on the line. Build the answer library so the next one takes two days instead of three weeks. That reuse instinct is a senior-analyst trait.
6. **Quantify.** Run `tools/fair_analysis.py`, change the inputs to your own calibrated estimates, and write the investment case.

Deliverable. Audit report + management review pack + metrics dashboard + board paper + questionnaire response.

Proof gate. Your board paper must fit on one page and survive the test: would a CFO who reads only the first two sentences know what you want and why? If not, rewrite.

Phase 7 — Interview conversion (Weeks 11–12, ~16 h)

Mission. Turn twelve weeks of artefacts into offers.

Steps

1. Work `05-interview/QUESTION-BANK.md` — 120 questions across six categories, with what a strong answer contains.
2. Build your **STAR bank**: 12 stories drawn from this lab plus your actual professional background. If you come from SOC, DFIR, pentest or CTI, your operational history is a genuine advantage in GRC interviews — most GRC candidates have never seen an attack. Lead with that.
3. Do the **case studies** in `05-interview/CASE-STUDIES.md` under timed conditions.
4. Build the **portfolio**: a sanitised public version of the SoA, the RoI approach, the incident classification memo, the FAIR analysis. Redact nothing real because none of it is real — that is the advantage of a lab company. Write it up as "an assessment I performed against a simulated EU payments institution," and be explicit that it is a lab. Nobody minds; everybody is impressed that you built it.
5. Write your positioning: your background, your certifications, plus this lab. For candidates with a technical security background the strongest story is "I can assess a control and also tell you whether an attacker would actually care about it" — which is rare and valuable.

Deliverable. Portfolio, STAR bank, timed case-study performances.

The self-assessment

Score yourself 1–5 on each, honestly, at the start and at the end.

Capability	Phase
Write a risk statement that separates cause, event and consequence	1
Define and defend likelihood/impact criteria	1
Translate board behaviour into written risk appetite	1
Scope an ISMS and justify exclusions	2
Scope a CDE and explain what expands it	2
Identify critical or important functions under DORA	2
Build a defensible Statement of Applicability	2
Distinguish design from operating effectiveness	3
Write a re-performable test procedure	3
Choose and justify a sample size	3
Judge evidence strength	3
Tier third parties against criteria, not vibes	4
Build a DORA Register of Information	4
Analyse concentration risk and propose realistic treatment	4
Classify an incident under DORA against the RTS criteria	5
Determine the GDPR Art. 33 awareness moment	5
Run a BIA and derive honest RTOs	5
Plan and perform an internal audit	6

Capability	Phase
Build metrics someone would act on	6
Write one page a board will read	6
Quantify risk in money and defend the model	6

Anything still at 3 or below after Phase 7: go back to that phase and redo the deliverable. The gaps are always in the phases you rushed.

A note on the regulatory dates in this lab

Regulation moves. The dates used here were current as of September 2026: Portugal's NIS2 transposition (Decreto-Lei 125/2025) in force 3 April 2026; the EU AI Act Digital Omnibus (Reg. EU 2026/1744) moving Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028, with Art. 50 transparency applying from 2 August 2026; the ISO 27001:2013→2022 transition having closed 31 October 2025.

Verify every date before you cite it in an interview. The habit of checking rather than reciting is itself the professional skill — and saying "that was the position as of [date], I'd confirm it's still current" is a strictly better answer than a confident wrong number.

Company Dossier: Norvela Pay

Your assessment target. Treat everything in this file as ground truth.

Version 1.0 · Lab scenario for GRC risk & compliance practice Fictional company. Any resemblance to a real entity is coincidental.

1. Why this company was designed this way

You need one organisation that legitimately triggers *multiple* regulatory regimes at once, because that is the situation real GRC people are hired into and the situation interviews probe. Norvela Pay is built so that:

Regime	Why it bites	What it forces you to practise
DORA (Reg. EU 2022/2554)	Authorised payment institution in the EU	ICT risk framework, Register of Information, incident classification, TLPT scoping, exit strategies
NIS2 / PT Decreto-Lei 125/2025	Subsidiary is an in-scope entity; also a digital provider	Registration with CNCS, 24h/72h/1-month reporting chain, management-body liability
GDPR	Processes payment + identity data of EU data subjects	RoPA, DPIA, transfers, breach notification, DSR
PCI DSS 4.0.1	Touches cardholder data through one product line	Scoping, segmentation, SAQ vs RoC, compensating controls
ISO/IEC 27001:2022 (+Amd 1:2024)	Customers demand the certificate	ISMS, SoA, internal audit, management review, certification cycle
SOC 2 Type II	US enterprise customers demand it	Trust Services Criteria, evidence over a period, exceptions
EU AI Act (Reg. 2024/1689, as amended by Reg. 2026/1744)	Runs an AI fraud-scoring and a credit-decisioning model	Risk classification, Art. 50 transparency, timeline realism

That overlap is the whole point. A control like MFA is evidence for six of those at once, and a real GRC analyst's value is knowing that and not testing it six times.

2. The business

Norvela Pay, S.A. — headquartered Lisbon, Portugal. Founded 2019. 340 employees. Revenue €61M (FY2025).

Norvela Pay is an **embedded payments and treasury platform**. Mid-market European retailers and marketplaces plug Norvela into their checkout and back office to:

1. Accept card, SEPA and open-banking payments (**PayRails** product)
2. Hold and move funds in multi-currency wallets (**Vault** product)
3. Get short-term working-capital advances against receivables (**Flow** product)
4. Screen transactions for fraud using an in-house ML model (**Sentinel**)

Regulatory status. Authorised as a Payment Institution by Banco de Portugal (licence PI-2021-0447), passported into 14 EEA states. The Flow product is delivered through a partnership with a licensed credit institution, Banco Astera (Spain), because Norvela cannot lend on its own licence.

Legal entities:

Entity	Country	Role	Headcount
Norvela Pay, S.A.	Portugal	Licensed PI, group parent, main engineering	240
Norvela Pay Iberia, S.L.	Spain	Sales, merchant onboarding, support	55
Norvela Tech Sp. z o.o.	Poland	Engineering hub, 24/7 platform ops (NOC)	40
Norvela Pay Inc.	USA (Delaware)	US sales entity, no processing	5

Why the entity structure matters. The Polish entity runs the night shift and therefore has production access. It is a separate employer with separate HR onboarding. That single fact breaks three controls in the lab — find them.

---

3. Governance as it actually exists

Board of Directors (Conselho de Administração) — 5 members. Meets monthly. Cybersecurity is a standing agenda item **only since March 2026**, added after the Banco de Portugal supervisory letter (see §9).

Role	Name	Note
CEO	Marta Quintela	Founder. Vocal that "compliance shouldn't slow the roadmap."
CFO	Duarte Salgado	Owns the DORA budget line. Sceptical of headcount asks.
CTO	Ivo Brandão	Founder. Owns engineering. Resists change-freeze windows.
COO	Sofia Rendeiro	Owns operations, vendor contracts, BCP. Your best ally.
Non-exec	Katarína Hoferová	Ex-regulator. Asks the hardest questions in the room.

Second line:

- **Chief Risk Officer — Helena Vaz.** Joined Jan 2026. Came from insurance, strong on enterprise risk, learning ICT risk. Reports to CEO.
- **Head of Compliance — Nuno Peralta.** AML/CFT focused. Has never run an ISO audit. Reports to CEO.
- **DPO — Cláudia Reis.** Part-time (0.5 FTE), also company secretary. *Flag this: is a part-time DPO with a secretarial role an Art. 38(6) conflict? That's a real interview question.*
- **CISO — vacant.** Left August 2026. **This is your role in the lab.** Currently the Head of Platform Engineering is "acting CISO," which is a first-line/second-line conflict you should write up on day one.

Third line: Internal Audit is one person, Rita Mendonça, who spends 80% of her time on AML file reviews. No ICT audit has ever been performed.

Committees: There is a Risk Committee on paper (charter dated 2022, never amended). It has met 3 times in 18 months. There is no Change Advisory Board; changes are approved in the pull request.

4. Technology estate

4.1 Cloud

AWS is primary — accounts:

Account	Purpose	Notes
`norvela-prod`	Production payments platform	eu-west-1 (Ireland), eu-central-1 (Frankfurt)
`norvela-staging`	Pre-prod	Contains a **restored copy of production data** from 2025-11
`norvela-dev`	Development	60 engineers have `PowerUserAccess`
`norvela-data`	Data lake, ML training	Sentinel + Flow model training data
`norvela-sandbox`	Merchant test environment	Public-facing API
`norvela-audit`	Log archive	CloudTrail org trail, 400-day retention

Azure — a single tenant for Microsoft 365 (Exchange, SharePoint, Teams, Entra ID). Entra ID is the identity provider for SSO into 31 SaaS apps.

On-prem — one Lisbon office server room with: a legacy Oracle DB running the merchant settlement reconciliation (the "Ledger"), two ESXi hosts, and the physical HSM cluster required for the card product.

4.2 The crown jewels (candidate list — you will refine this)

1. **The Ledger** (Oracle, on-prem) — the authoritative record of merchant balances. If it's wrong, Norvela owes money it can't prove.
2. **HSM cluster** — card data encryption keys. PCI-critical.
3. **Vault balance service** (AWS, Kubernetes) — real-time fund movement.
4. **Sentinel model + feature store** — fraud decisions.
5. **Entra ID tenant** — compromise = everything.
6. **The `norvela-data` lake** — full transaction history, 7 years.

4.3 Known technical facts (these are your findings source)

These are deliberate. Each one maps to at least one control failure.

- Production deploys happen **12–20 times per day** via GitHub Actions. There is no separate deployment approval; PR merge triggers deploy.
- **Break-glass access**: a shared `prod-admin` AWS role exists. 11 people can assume it. There is no session recording. It was used 43 times last quarter.
- **MFA**: enforced in Entra ID for all staff. **Not** enforced on the AWS root accounts of `norvela-sandbox` and `norvela-dev`. Nobody knows who holds the sandbox root credentials.
- **Staging data**: the November 2025 production restore in staging includes live PANs and customer names. It has never been masked. 60 developers can read it. *This is your GDPR + PCI headline finding.*
- **Logging**: CloudTrail is on in all accounts and centralised to `norvela-audit`. But application-level logs from the Vault service are retained for **14 days** only, because of cost.
- **Backups**: RDS automated backups, 7 days. The Ledger (Oracle) is backed up to tape weekly and shipped to an Iron Mountain facility. **The Ledger restore has never been tested.** Last documented attempt: 2022, failed.

- **Vulnerability management**: Snyk on repos, AWS Inspector on workloads. There are 1,247 open findings; 38 are critical and older than 180 days. No SLA is documented.
- **Patching**: Kubernetes nodes are immutable and replaced weekly. The two ESXi hosts are on a version that went end-of-support in 2024.
- **Endpoint**: Jamf for 280 Macs, Intune for 45 Windows machines. 15 Linux workstations in the Poland office are **unmanaged**.
- **Network**: no segmentation between the corporate network and the Lisbon server room. The HSM cluster is reachable from any office VLAN.
- **Secrets**: AWS Secrets Manager is used for new services. Legacy services read from a `.env` file baked into the container image. A 2025 secret scan found 22 live credentials in Git history; 6 have not been rotated.
- **Sentinel model**: retrained monthly on production data. No documented approval gate, no bias testing, no model card. Decisions are **auto-declining** transactions with no human review path below €500.
- **Flow model**: scores merchant creditworthiness. Outputs feed Banco Astera's lending decision. *Is this an Annex III high-risk AI system? Whose obligation — Norvela's as provider, or the bank's as deployer? Argue it.*

---

5. Data

5.1 Personal data processed

Category	Volume	Lawful basis (as claimed)	Where
Merchant contact details	~14,000	Contract	Salesforce, AWS
End-customer payment data (PAN, name)	~40M transactions/yr	Contract + legal obligation	AWS, HSM, Ledger
KYC/identity docs of merchant directors	~11,000	Legal obligation (AML)	Onfido → S3
Transaction behaviour for fraud scoring	All transactions	**Legitimate interest**	`norvela-data`
Employee data	340	Contract / legal	BambooHR, M365
Support call recordings	~9,000/yr	**Consent** (claimed)	Talkdesk (US)
Website analytics	—	Consent	GA4

Deliberate problems planted here — find them yourself before reading the answer key in `01-scenario/99-FINDINGS-KEY.md`: - One lawful basis is almost certainly wrong for what's actually done with it. - One processor is in a third country with no documented transfer mechanism. - One category is retained far beyond any stated retention period. - The RoPA (`03-workbooks`) is 14 months out of date and misses two systems.

5.2 Retention as practised

There is a retention policy document (2021). It says "7 years for financial records." In practice, nothing is ever deleted. The data lake holds records from 2019. Support recordings are kept indefinitely.

---

6. Third parties (the TPRM problem)

Norvela uses 31 SaaS applications and 9 infrastructure providers. Here are the ones that matter for the lab. The full machine-readable register is in `03-workbooks/vendors.csv`.

Vendor	Service	Criticality	Problem to find
AWS	Cloud infrastructure	Critical / supports CIF	Concentration risk; no tested exit plan
Banco Astera (ES)	Lending partner for Flow	Critical	Is this ICT third-party or a business partner? Scope argument
Onfido	KYC identity verification	Important	Sub-processor chain not mapped
Talkdesk	Contact centre	Important	US-hosted; call recordings = personal data
Snowflake	Analytics warehouse	Important	Added by the data team; **never went through vendor review**
Datadog	Observability	Important	Logs contain PANs in 3 known cases
A small Portuguese ISV, "Sertã Systems"	Ledger reconciliation support	**Critical**	Two-person company. Has standing VPN access to the Oracle Ledger. Contract from 2019, no DORA clauses, no exit plan, no audit rights. **This is the single worst vendor risk in the lab.**
GitHub	Source control + CI/CD	Critical	Deploy pipeline = production change path
Cloudflare	WAF/CDN	Critical	Single point of failure for all merchant traffic

The DORA Register of Information exercise: you will build a real RoI from this vendor list using the ITS (EU) 2024/2956 templates. That is the single most job-relevant artefact in this lab.

7. What already exists (your starting documentation)

Do not assume a greenfield. Real jobs start mid-mess.

Document	State
Information Security Policy	v2.1, approved 2023, never reviewed since
Acceptable Use Policy	Exists, signed by 61% of staff
Access Control Policy	Exists, references a joiner-mover-leaver process that HR does not follow
Incident Response Plan	v1.0, 2022. Does not mention DORA or NIS2 timelines. Never exercised.
Business Continuity Plan	Exists for the Lisbon office (fire/flood). Nothing for cloud outage.
BIA	Never performed
Risk register	A spreadsheet with 23 entries, last updated 2025-04. Scored High/Medium/Low with no defined criteria.
RoPA	Exists, 14 months stale
DPIA	One, for the Sentinel model, dated 2023, two pages
SoA	Does not exist
Vendor register	Procurement's spreadsheet — 22 of 40 vendors
Asset inventory	Three partial inventories that disagree with each other
Training records	Annual awareness training, 74% completion

8. The people problem

- Engineering views security as a blocker. The CTO has said in writing (Slack, quoted in `04-evidence/`) that "the audit is a tax."
- The Poland NOC team was never included in the awareness training rollout because their HR system is separate.
- Two engineers left in July 2026. Their AWS IAM users are still active. Their Entra accounts were disabled correctly. *Why the difference? Because the leaver process only covers SSO-integrated apps. This is a joiner-mover- leaver finding with teeth.*
- The Head of Platform Engineering is "acting CISO" — first line policing itself.

9. Live pressures (your clock)

These give the lab urgency and give you deadline-management practice.

1. **Banco de Portugal supervisory letter (2026-03-11)** — following the 2026 DORA Register of Information submission, the supervisor noted "material data quality deficiencies" in Norvela's RoI and requested a remediation plan. **Response due 2026-11-30.**
2. **ISO 27001 Stage 1 audit booked for 2027-02-15.** Certification body: fictional "Atlântico Certificação." The SoA does not exist yet.
3. **NIS2 / RJC** — Portugal's Decreto-Lei 125/2025 entered into force 2026-04-03. Norvela must determine whether it is an essential or important entity, register with CNCS, and align. Note the DORA *lex specialis* argument — work out where DORA displaces the RJC for a payment institution and where it does not.
4. **Largest customer (a German marketplace) has issued a security questionnaire** — 214 questions, due in 3 weeks, and their contract renewal (€4.1M ARR) depends on it.
5. **An incident occurred 2026-09-08** — see `01-scenario/10-INCIDENT.md`. You must classify it under DORA, decide on NIS2 and GDPR notification, and run the post-incident process.

10. Risk appetite (as the board would articulate it if pushed)

Nobody has written this down. One of your Phase 1 deliverables is to draft it and get it "approved." Use these signals from board behaviour:

- Will accept availability risk for non-payment features; will not accept any single-transaction settlement error.
- Fears regulatory action more than a breach — a Banco de Portugal intervention is existential for the licence.
- Will spend on things customers ask about (ISO cert) faster than on things only regulators ask about (BIA).
- Zero tolerance stated for AML failures; no stated tolerance for anything else.

Your job in Phase 1 is to turn that into quantified appetite statements with thresholds. That exercise alone is a senior-level interview answer.

Incident Pack NOR-2026-0908

Use this for incident classification, regulatory notification and post-incident review practice. Work it in real time against the clock.

How to use this pack

Do **not** read the whole thing at once the first time. Read one timeline block, make your decisions, write them down with a timestamp, then read the next block. That is how the information actually arrives in a real incident, and the discipline of deciding on incomplete information is precisely what separates people who have done this from people who have read about it.

Your decision points are marked **[DECIDE]**. Write your answer before moving on.

T+0 — Tuesday 2026-09-08, 03:14 WEST

The Poland NOC receives a Datadog alert: the Vault balance service in `eu-west-1` is returning HTTP 500 on 12% of requests. The on-call engineer (Poland, contractor via an agency) restarts the service. Errors drop to 3%. He does not open a ticket because "restart fixed it."

T+4h — 07:20 WEST

A merchant in Germany emails support: their settlement report shows two payouts they did not initiate, totalling €48,200, to an IBAN they don't recognise. Support tags it "billing query" and routes it to Finance with a 48-hour SLA.

[DECIDE 1] At this point, is anything reportable to anyone? On what basis? What is the single question you most need answered in the next 30 minutes?

T+9h — 12:05 WEST

Finance notices three more merchants with the same pattern. Total now €310,000 across 5 merchants, all to two beneficiary IBANs in a non-EEA jurisdiction. Finance escalates to the COO. The COO calls the acting CISO.

T+11h — 14:30 WEST

Initial technical finding: the payouts were made through the legitimate Vault API using a valid API key belonging to a *Norvela internal service account*, `svc-settlement-batch`, not a merchant key. The calls originated from an IP in a commercial VPN range. The service account's key was last rotated in **2023**.

[DECIDE 2] Under **DORA Art. 18**, run the classification. You need the criteria from the RTS on incident classification: clients affected, data losses, economic impact, service downtime, geographical spread, criticality of services affected, reputational impact. Does this meet the **major incident** threshold? Write your reasoning against each criterion — the reasoning is what a supervisor asks for, not the conclusion.

[DECIDE 3] The DORA initial notification clock. When does it start, and by when must the initial notification reach Banco de Portugal? What are the intermediate and final report deadlines? *Do not guess — look it up and cite the article. Getting this wrong in an interview is fatal; saying "I'd confirm the exact deadline against Art. 19 and the RTS before committing" is not.*

[DECIDE 4] Is this also a **personal data breach** under GDPR Art. 4(12)? If yes, is it notifiable under Art. 33, and is Art. 34 communication to data subjects triggered? Note the distinction between the merchants (Norvela's customers, mostly legal persons) and any natural persons involved.

[DECIDE 5] Portugal's RJC (DL 125/2025) also has notification duties. Does DORA displace them here as *lex specialis*? Write the argument both ways and then commit to a position. This exact question is being argued by real compliance teams right now and a good answer will impress anyone interviewing you.

T+14h — 17:45 WEST

Log review finds the truth, and it is worse:

- The `svc-settlement-batch` credential was one of the **6 unrotated secrets found in Git history in the 2025 secret scan.** The scan report is in `04-evidence/secret-scan-2025.md`. It was assigned to a ticket that was closed as "won't fix — legacy service, scheduled for decom Q1 2026." The decom never happened.
- The repository containing it was **public for 11 days in March 2024** due to a misconfigured GitHub org setting.
- Vault application logs are retained **14 days**. The intrusion may predate the log window. **You cannot prove when access began.** You can only prove the earliest event you still have logs for.

[DECIDE 6] You cannot establish the start date. How do you communicate that to (a) the board, (b) the supervisor, (c) affected merchants? Write the actual sentence you would use for each. Vague hedging fails; overclaiming certainty is worse. This is a communication skill interviews test hard.

[DECIDE 7] What compensating evidence sources exist that might extend your visibility backwards? List at least five before reading on. *(CloudTrail in `norvela-audit` at 400 days; VPC flow logs; the bank's own records of received payments; Datadog metric retention vs log retention; GitHub audit log; HSM logs; beneficiary IBAN first-seen date in the AML system.)*

T+2 days — 2026-09-10

CloudTrail (400-day retention — the one control that saves you) shows the credential was first used from the VPN range on **2026-07-29**. Six weeks of access. During that window there were **no** unauthorised payouts until September. The attacker was reconnoitring.

Total confirmed loss: €310,000, of which €96,000 is recoverable. Merchants affected: 5. End-customers affected: 0 directly, but the `norvela-data` lake was queried — **41,000 customer records** were read.

[DECIDE 8] Now re-run your DORA classification with the full facts. Did your T+11h answer change? Document *why* — supervisors care enormously about whether your classification was reasonable *at the time you made it*, not whether it matched the final facts. Write the reclassification note.

[DECIDE 9] GDPR Art. 33: the 72-hour clock runs from **awareness**. When did Norvela become "aware"? 03:14 on the 8th? 12:05? 14:30? T+2 days? Defend your answer. This is the highest-frequency GDPR interview question there is.

T+9 days — 2026-09-17

Root cause analysis complete. Contributing factors:

1. Secret in Git history, never rotated, ticket closed without remediation
2. No credential rotation policy for service accounts
3. Repository briefly public — no alerting on org visibility change
4. No egress filtering; the data lake query went to an external endpoint
5. Application log retention too short to support investigation
6. On-call engineer restarted a service without raising a ticket — no "unexplained anomaly" escalation criterion existed
7. The decom ticket was closed by the same team that owned the risk

[DECIDE 10] Which of these are *findings* (control failures) and which are *risks* (conditions that could cause future loss)? They are not the same thing and conflating them is the most common junior GRC error. Produce: - a findings list with severity, owner, and remediation dates - risk register entries with inherent/residual scoring - **one** entry for the board risk report, written in business language, under 120 words

---

Deliverables for this pack

Produce all of these. They are portfolio pieces.

1. **Incident classification memo** (DORA Art. 18 criteria, one page)
2. **Regulatory notification drafts** — initial notification to Banco de Portugal; GDPR Art. 33 notification to CNPD; decision note on RJC/CNCS
3. **Merchant communication** — the actual email to the 5 affected merchants
4. **Board paper** — one page, what happened, what it cost, what we're doing
5. **Post-incident review** — findings, root causes, corrective actions with owners and dates
6. **Risk register updates** — new and revised entries with scoring rationale
7. **Lessons-learned control changes** — which specific ISO 27001 Annex A and DORA articles now need attention, and what evidence will prove closure

Self-check

If your post-incident review blames the on-call engineer, rewrite it. He followed a process that did not exist. Findings that terminate at a person rather than at a system are how you fail a Big 4 interview.

Lab Setup

Target: a working GRC lab in about 3 hours, most of which is downloads.

Hardware: 16 GB RAM is comfortable, 8 GB works if you skip the scanning profile. ~60 GB disk. Linux or macOS; Windows needs WSL2.

Part 1 — CISO Assistant (your GRC platform) — 30 min

This is the centre of the lab. It is AGPL-licensed, self-hosted, and carries built-in libraries for ISO 27001:2022, NIS2, DORA, GDPR, SOC 2, PCI DSS 4.0.1, NIST CSF 2.0, CIS, EU AI Act, ISO 42001 and ~200 more — plus automatic mapping between them. That last part is what makes it worth the setup: you will physically see one control satisfying six frameworks, which is the single most important intuition in this job.

```
git clone --single-branch -b main \
  https://github.com/intuitem/ciso-assistant-community.git
cd ciso-assistant-community
./docker-compose.sh          # Linux / macOS
# ./docker-compose.ps1       # Windows (Docker Desktop + WSL2)
```

It prompts for a superuser email and password. Then open **https://localhost:8443** and accept the self-signed certificate.

> Use a release tag rather than `main` if you want stability — `main` is the merge upstream and can break. `git tag -l | tail -5` then `git checkout` it.

First things to do inside it, in this order:

1. **Governance → Libraries → Load** the frameworks you need. Start with exactly three: `ISO 27001:2022`, `DORA`, `GDPR`. Adding twenty on day one is how people drown. Add NIS2, PCI DSS 4.0.1 and EU AI Act in Phase 3.
2. Create a **Domain** called `Norvela Pay` and **Perimeters** for each product line (PayRails, Vault, Flow, Sentinel) plus `Corporate`.
3. Load your assets from `03-workbooks/assets.csv` — the data import wizard takes CSV, or use the REST API (see `tools/api-examples.sh`, which creates the domain and perimeters and imports `assets.csv` for you).
4. Do **not** start an audit yet. Scope first. Phase 2 explains why.

The REST API is the reason to prefer this tool over clicking: create a Personal Access Token from your profile and drive it with `Authorization: Token <token>` (note: `Token`, not `Bearer`). Automating evidence collection through that API is a portfolio piece on its own.

Part 2 — Second opinion platform: SimpleRisk — 15 min (optional)

Worth doing once, because interviewers ask "which GRC tools have you used" and two is a better answer than one. It also models risk differently, which teaches you that the tool's data model is an opinion, not a law.

```
docker run -d --name simplerisk -p 8080:80 -p 8444:443 simplerisk/simplerisk:latest
```

Then http://localhost:8080. (HTTPS is mapped to 8444 because CISO Assistant already owns 8443.) It carries CIS Controls, NIST 800-171, PCI DSS and HIPAA self-assessments out of the box.

Skip this if you are short on time. CISO Assistant alone is enough.

Part 3 — The supporting stack — 20 min

```
cd norvela-grc-lab/02-stack
docker compose up -d
```

Service	URL	Why it exists
Juice Shop	http://localhost:3000	A target that actually fails controls
DVWA	http://localhost:8081	Second target (admin/password)
OpenSearch	http://localhost:9200	Evidence store you can query
Dashboards	http://localhost:5601	Build a real control-monitoring dashboard
Mailpit	http://localhost:8025	Proves an alert fired

Add vulnerability scanning when you get to Phase 3 (control assessment):

```
docker compose --profile scanning up -d
# https://localhost:9392  admin / labadmin
# First start syncs the NVT feed — 30-60 min. Leave it.
```

Part 4 — Cloud configuration assessment — 30 min

You need a cloud account to assess. Two honest options:

Option A — a real AWS free-tier account (recommended). Build a small, deliberately flawed estate: an S3 bucket with public read, a security group open on 0.0.0.0/0:22, an IAM user with no MFA and an ancient access key, an unencrypted RDS snapshot, CloudTrail disabled in one region. Then scan it. Total cost if you stay in free tier and tear down after: near zero. Set a billing alarm at €5 before you start, and delete everything when done.

Option B — LocalStack, if you will not touch a real account. Free tier covers enough services for most Prowler checks.

Then:

```
pip install prowler
prowler aws --compliance cis_3.0_aws
prowler aws --compliance iso27001_2013_aws
prowler aws --compliance nis2_aws
prowler dashboard          # local UI over your findings
```

Prowler ships compliance mappings for CIS, NIST 800-53, NIST CSF, ISO 27001, PCI DSS 4.0, SOC 2, GDPR, HIPAA, FedRAMP, NIS2, MITRE ATT&CK and more. The exercise is not "run the scanner." The exercise is: take the JSON output, map each failed check to an ISO 27001 Annex A control and a DORA article, and decide which failures are *risks* and which are *findings*. That translation step is the job.

Export findings for the register:

```
prowler aws --compliance iso27001_2013_aws --output-formats json csv \
  --output-directory ./prowler-out
```

Part 5 — Host hardening evidence — 20 min

```
# Debian/Ubuntu host or VM
sudo apt install -y openscap-scanner ssg-debderived
oscap xccdf eval --profile cis_level1_server \
  --results scan-results.xml --report scan-report.html \
  /usr/share/xml/scap/ssg/content/ssg-ubuntu2404-ds.xml
```

`scan-report.html` is a genuine piece of audit evidence. Attach it to a control in CISO Assistant. That is what "evidence" means — a machine-generated, timestamped artefact, not a screenshot of a settings page.

Learn this distinction now, because it is an interview question:

Weak evidence	Strong evidence
Screenshot of a config screen	Config exported by API with a timestamp
"The policy says we do X"	A log showing X happened 400 times last month
An email saying access was reviewed	The reviewed list, the reviewer, the date, the removals that followed
A vendor's ISO certificate	The certificate *plus* the Statement of Applicability *plus* whether your service is in scope

---

Part 6 — Quantitative risk — 10 min

```
pip install numpy matplotlib
python3 tools/fair_analysis.py       # run from 02-stack/
```

This models the settlement-fraud scenario from the incident pack with a Monte Carlo simulation and gives you a loss-exceedance curve. Being able to say "the 90th percentile annual loss for this scenario is €X, and this control reduces it to €Y, at a cost of €Z" is what separates GRC people who get listened to by a CFO from GRC people who show heat maps.

Verify your lab

```
bash tools/healthcheck.sh            # run from 02-stack/
```

What you deliberately do NOT need

- **Not a commercial GRC tool.** Archer/ServiceNow/OneTrust experience is nice on a CV but nobody expects you to have licensed one. Knowing the *concepts* transfers completely; every one of these tools is a risk register, a control library, a mapping engine and a workflow.
- **Not a certification first.** Build the artefacts, then certify. A portfolio of a real RoI, a real SoA and a real incident pack beats a certificate with nothing behind it. If you already hold one (CISM, CISA, ISO 27001 LI), this is what gives it substance.
- **Not a big lab.** Everything above runs on one laptop.

Scenario Evidence

Secret scan — Git history, norvela GitHub org (2025)

> **Scenario artefact.** Fictional. All credential values are redacted placeholders — nothing here is a real secret.

Field	Value
Scan type	Full Git history, all repositories in the `norvela` org
Tooling	Open-source secret scanner, run once by Platform Engineering
Scheduled re-scan	None defined
Live credentials found	**22**
Rotated after the scan	16
Not rotated	**6**

The six unrotated credentials

#	Credential (redacted)	Type	Repository	Ticket	Ticket status
1	`svc-settlement-batch` — `AKIA****************`	AWS IAM access key	`settlement-batch`	PLAT-2291	**Closed — "won't fix: legacy service, scheduled for decom Q1 2026"**
2	`svc-legacy-etl` — `AKIA****************`	AWS IAM access key	`legacy-etl`	PLAT-2292	Closed — "won't fix: legacy service, scheduled for decom Q1 2026"
3	Ledger adapter DB password `********`	Oracle DB credential	`ledger-adapter`	PLAT-2293	Open — no assignee
4	Notification service SMTP password `********`	SaaS credential	`notification-svc`	PLAT-2294	Open — "blocked on vendor"
5	Datadog API key `********`	Observability API key	`infra-config`	PLAT-2295	Open
6	Internal admin-console session secret `********`	Application secret	`admin-console`	PLAT-2296	Open — "low priority, internal only"

Ticket trail — PLAT-2291

- Raised by: Platform Engineering (scan owner)
- Assigned to: Platform Engineering (service owner)
- Closed by: Platform Engineering
- Resolution: *Won't fix — legacy service, scheduled for decommission Q1 2026.*
- Decommission ticket: none linked
- Independent verification of closure: none

Context recorded in the scan notes

- The `settlement-batch` repository was **public for 11 days in March 2024** after an organisation visibility setting was changed. No alert fired, and no retrospective assessment of what was exposed was performed.

What an assessor should ask of this artefact

- Who decided "won't fix", and did anyone outside the owning team agree?
- What compensating control applied while the decommission was pending?
- Is a one-off scan with no re-scan date a control at all?

Slack excerpt — #eng-leads (2026)

> **Scenario artefact.** Fictional people, fictional company. Collected as evidence of tone at the top for the governance assessment.

Context. Thread after the Head of Compliance asked whether engineering could support evidence collection for the ISO 27001 Stage 1 audit.

> **Ivo Brandão (CTO):** Honest view: the audit is a tax. It doesn't make us safer, it makes us slower. We deploy 15–20 times a day because that's how we beat bigger competitors.
>
> **Ivo Brandão (CTO):** Happy to give read-only access to whatever they need, but I'm not putting a change freeze or an approval committee in front of the pipeline. PR review *is* our approval.
>
> **Head of Platform Engineering (acting CISO):** +1, we can export what they need from GitHub. Agree on no freeze.
>
> **Sofia Rendeiro (COO):** Can we at least talk about the payment path separately? Not everything, just what touches settlement.
>
> *(no reply in thread)*

What an assessor should take from this

- **Tone at the top** — the risk-taking culture is stated in writing by a board member. Relevant to ISO 27001 Clause 5.1 and DORA Art. 5.
- **The acting CISO agrees with the CTO** — the first-line/second-line conflict in practice, not just on the org chart.
- **The COO's question is the right one** and went unanswered. Scoping a control to the payment path is the compromise you will need in `05-interview/CASE-STUDIES.md`, Case 3.

Interview Question Bank

120 questions. Every one is answerable from work you will have done in this lab — that is the design. Where a question has a trap, the trap is named.

How to use this. Do not read the answers first. Answer aloud, out loud, into a recorder, then compare. The gap between what you know and what you can say under mild pressure is the entire problem this bank exists to close.

Category 1 — Risk fundamentals (25)

1. What is the difference between a risk and a finding? *Strong answer separates a present-tense control defect from a future loss scenario with cause, event and consequence — and says that one risk is usually caused by several findings. Weak answers use the words interchangeably.*
2. Walk me through how you'd run a risk assessment for a payments platform you've never seen before.
3. Inherent vs residual risk — and what sits between them?
4. Risk appetite vs risk tolerance vs risk capacity. Give an example of each from a firm you know.
5. Your likelihood scale says "Possible = once in 2–5 years." How did you arrive at those boundaries?
6. A business owner wants to accept a critical risk. Walk me through what happens next.
7. Who should own a risk — the person who can fix it, or the person who suffers if it materialises? Defend your answer.
8. When is a heat map the wrong tool?
9. Explain FAIR to someone who has never heard of it, in 90 seconds.
10. Why does a control reduce vulnerability but not threat event frequency? *This is a genuine discriminator. Most candidates get it wrong.*
11. Your Monte Carlo says the P90 annual loss is €3.9M. The CFO says "you made that up." What do you say?
12. How many risks should a register for a 340-person company have? *There is no right number, but "however many there are" is a bad answer and "35–45 well-formed risks, because beyond that nobody reads it and below that you've aggregated away the detail" is a good one.*
13. Qualitative or quantitative risk assessment — which and when?
14. What is a key risk indicator, and how is it different from a key performance indicator?
15. Give me a KRI for third-party concentration risk.
16. How do you handle a risk that crosses three departments and nobody wants?
17. What is risk velocity and why might it matter more than likelihood?
18. Your register has 23 entries, all scored High or Medium, last updated 18 months ago. What do you do in your first week?
19. How do you aggregate risk upward for a board without losing meaning?
20. What is a risk that you would deliberately *not* put in the register?
21. Explain the three lines of defence. Now tell me what's wrong with it.
22. Your acting CISO reports to the CTO. Why is that a problem, and what would you do if you couldn't change it immediately?
23. How do you set risk appetite when the board has never articulated one?
24. What's the difference between a risk assessment and a gap assessment?

25. Tell me about a risk you were wrong about.

Category 2 — Frameworks and standards (25)

26. ISO 27001 vs ISO 27002 vs ISO 27005 — what does each do?
27. How many controls are in ISO 27001:2022 Annex A and how are they organised? *93, across organisational (37), people (8), physical (14), technological (34).*
28. Name three controls that are new in the 2022 revision and why they were added. *Threat intelligence 5.7, cloud services 5.23, data leakage prevention 8.12, configuration management 8.9, information deletion 8.10, data masking 8.11, monitoring 8.16 — pick three and explain the gap each closed.*
29. What is Amendment 1:2024 and what does it actually require? *Climate-change determination in Clause 4.1 and a note in 4.2. No new Annex A controls. Candidates who claim new controls reveal they read a blog rather than the standard.*
30. What is a Statement of Applicability and why do auditors read the exclusions first?
31. Walk me through the ISO 27001 certification lifecycle.
32. Stage 1 vs Stage 2 audit.
33. Major nonconformity vs minor vs observation. Give an example of each.
34. What does Clause 9.3 require, and why is it the most commonly missed?
35. SOC 2 Type I vs Type II.
36. Name the five Trust Services Criteria. Which are optional?
37. A customer asks for your SOC 2. You have ISO 27001. What do you say?
38. What is a bridge letter?
39. NIST CSF 2.0 — what changed from 1.1? *The Govern function was added, making six: Govern, Identify, Protect, Detect, Respond, Recover.*
40. When would you use NIST CSF over ISO 27001?
41. PCI DSS: what determines your SAQ type vs needing a RoC?
42. What expands PCI scope unexpectedly? *Answer from the lab: PANs in observability logs, and unmasked production data in staging.*
43. What is a compensating control and what makes one acceptable?
44. Explain the difference between a framework, a standard, a regulation and a benchmark.
45. How do you map controls across six frameworks without testing six times?
46. What is a control mapping's biggest failure mode? *Assuming a mapped control satisfies both at the same depth. ISO's "access control" and PCI's requirement 7 are not the same evidence bar.*
47. CIS Controls — what are Implementation Groups for?
48. What is ISO 42001 and who needs it?
49. ISO 27701 — what is it and what does it extend?
50. If you could only implement ten controls at a new company, which ten?

Category 3 — EU regulation (25)

51. What is DORA and who does it apply to?
52. DORA's five pillars. *ICT risk management; incident reporting; resilience testing; third-party risk; information sharing.*
53. What is the Register of Information and why does it exist?
54. Walk me through how you'd build one from a messy vendor spreadsheet.
55. What makes a function "critical or important" under DORA?
56. What is a CTPP and how does one get designated?

57. What must a DORA-compliant contract contain?
58. What is threat-led penetration testing and who has to do it?
59. How would you classify a major incident under DORA?
60. What are the DORA reporting deadlines? *Say the structure — initial, intermediate, final — and then say you would confirm exact hours against Art. 19 and the RTS rather than quote from memory. That is the correct professional answer.*
61. What is NIS2 and how is it different from NIS1?
62. Portugal transposed NIS2 how, and when did it take effect? *Decreto-Lei 125/2025, published 4 December 2025, in force 3 April 2026, establishing the Regime Jurídico da Cibersegurança. CNCS is the lead authority, CERT.PT the national CSIRT.*
63. Essential vs important entity — what turns on the distinction?
64. NIS2 imposes management-body liability. What does that mean in practice?
65. Where does DORA displace NIS2 as *lex specialis*, and where doesn't it?
66. GDPR Art. 33 — when does the 72-hour clock start? *From awareness, not discovery of full facts. The lab incident is built to make you argue this.*
67. When is Art. 34 communication to data subjects required?
68. What is a DPIA and when is it mandatory?
69. Controller vs processor vs joint controller. Give an example where the answer is genuinely contested.
70. What transfer mechanisms exist post-Schrems II and what does a TIA involve?
71. Can a part-time DPO who is also company secretary be a conflict under Art. 38(6)? Argue it.
72. What is legitimate interest and what does the balancing test require?
73. EU AI Act — what are the risk tiers?
74. What changed with the Digital Omnibus? *Reg. (EU) 2026/1744 moved Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028; Art. 50 transparency applied from 2 August 2026.*
75. A credit-scoring model feeds a partner bank's lending decision. Who is the provider and who is the deployer, and does it matter?

Category 4 — Control testing and audit (20)

76. Design effectiveness vs operating effectiveness.
77. How do you choose a sample size?
78. A control operates daily for 12 months. You test 25 instances and find one failure. What do you conclude?
79. Rank these from strongest to weakest evidence: a screenshot, a policy document, an API export with timestamps, an email confirming a review.
80. How would you test a joiner-mover-leaver control?
81. How would you test that backups work? "*Backups exist*" *is not the control.* "*Restores succeed within RTO*" *is.*
82. What makes a test procedure re-performable?
83. What is a walkthrough and when do you do one?
84. You find the same finding as last year, unremediated. What now?
85. The control owner disagrees with your finding. How do you handle it?
86. How do you audit a control that is fully automated?
87. What is continuous control monitoring and what does it require?

88. A vendor gives you their ISO 27001 certificate. What do you ask for next? *The SoA and the scope statement — a certificate whose scope excludes the service you buy is worthless to you.*
89. How do you test segregation of duties in a company where engineers deploy their own code?
90. What is a management representation and why does it not substitute for evidence?
91. How do you decide finding severity?
92. Write me a finding. Out loud. Condition, criteria, cause, consequence, recommendation.
93. What do you do when there is no evidence because the control has never operated?
94. How do you scope an internal audit programme for the year?
95. What's the difference between an internal audit and a self-assessment?

Category 5 — Third party and operational (12)

96. How do you tier vendors?
97. What do you do about a critical vendor that is a two-person company?
98. How do you assess a vendor that refuses to answer your questionnaire?
99. What is concentration risk and why is "multi-cloud" usually the wrong answer to it?
100. What belongs in an exit plan, and how do you know it works?
101. How do you map a sub-processor chain you have no visibility into?
102. A vendor was breached. Walk me through your first 24 hours.
103. How do you handle shadow IT discovered through an expense report?
104. What is a right-to-audit clause worth if you never exercise it?
105. How do you assess a vendor's vendor?
106. What questions actually differentiate vendors, versus which are theatre?
107. How would you shorten a 214-question customer security questionnaire process from three weeks to two days?

Category 6 — Behavioural and situational (13)

108. Tell me about a time you had to deliver bad news to an executive.
109. The CTO says "the audit is a tax." What do you say to him?
110. How do you get engineering to care about compliance?
111. You have 90 days and a broken programme. What are your first three moves?
112. Tell me about a time you were wrong.
113. How do you prioritise when everything is a regulatory deadline?
114. A board member asks "are we secure?" What do you say?
115. You discover the company has been non-compliant for two years. What now?
116. How do you say no to a business request?
117. Describe a time you changed someone's mind.
118. What's the most useless compliance activity you've seen, and why?
119. Why GRC, after years in offensive and detection work? *If this is your path, the answer is genuinely strong: you have seen what attackers actually do, so you can tell which controls matter and which are paperwork. Most GRC candidates cannot. Lead with it.*
120. What would you do in your first 30 days here?

The four answer patterns that work

For technical questions — Structure, Specific, Caveat. Name the framework or structure, give a specific example from your lab work, then state the limit of your certainty. "Under DORA the classification runs against seven criteria — clients affected, data losses, economic impact, downtime, geographic spread, criticality, reputation. In the settlement-fraud case I worked, it met the threshold on economic impact and criticality even before we knew the dwell time. I'd confirm the exact quantitative thresholds against the RTS before committing a classification in writing."

For "how would you" questions — Scope, Sequence, Success. What you'd scope, in what order, and how you'd know it worked.

For behavioural — STAR, with the number at the end. Situation and task in two sentences. Action in four. Result with a figure.

When you don't know — say so, then show how you'd find out. "I don't know that off the top of my head. I'd check the RTS and the national competent authority's guidance, because submission windows are set nationally." This scores *better* than a confident wrong answer with every interviewer worth working for.

Timed Case Studies

Six cases in the formats real GRC interviews use. Do them under the stated time limit with a timer running. Time pressure is the variable being tested — you already know most of the content.

Case 1 — The whiteboard risk assessment (20 min, verbal)

> "*A fintech has just acquired a small company. 40 people, one product, AWS, no security team. You have 20 minutes to tell me how you'd assess the risk of integrating them. Go.*"

What they are testing. Whether you have a repeatable method or you improvise. Whether you ask before you answer.

Structure that works: 1. **Clarify first (2 min).** What's the integration model — full absorption, or run separately? Are they in a regulated perimeter now? Does their product touch our customers' data? Timeline? *Asking these is scored. Candidates who launch straight into "first I'd do an asset inventory" lose points.* 2. **Scope (3 min).** Entities, systems, data, people, contracts. 3. **Method (5 min).** Crown jewels → threat scenarios → existing controls → inherent/residual → appetite comparison. 4. **The specifics that matter here (5 min).** Acquisitions have a characteristic risk profile: unknown credentials, unmanaged endpoints, personal accounts holding company data, undocumented vendor contracts that now bind you, and the acquired firm's own breach history which you inherit. Name those; they show you have thought about *acquisitions*, not just risk generally. 5. **Output and timeline (3 min).** What you'd deliver, when, and what you'd need from whom. 6. **What would stop the deal (2 min).** Have an answer. "Evidence of an unreported breach" and "a critical contract with no assignment clause" are good ones.

Case 2 — The incident classification (30 min, written)

Use `01-scenario/10-INCIDENT.md` at the T+11h information state only.

> "*Here is what you know eleven hours in. Write the classification memo and the recommendation to the executive team. One page.*"

Scored on: whether you classify against stated criteria rather than instinct; whether you state what you don't know; whether you give a clear recommendation rather than options; whether you handle the notification clock explicitly.

The trap. Candidates wait for certainty. The regulatory clock does not. A memo that says "we cannot yet confirm the start date; on the information available this meets the major threshold on economic impact and criticality; I recommend we notify on the assumption it is major and revise if facts change" is the correct answer.

Case 3 — The hostile stakeholder (15 min, role-play)

> *Interviewer plays Ivo Brandão, CTO. You are proposing a change freeze during the ISO audit window and a deployment approval gate.*

His lines, which you should expect: - "We deploy 20 times a day. Your gate will halve our velocity." - "The audit is a tax. It doesn't make us safer." - "Name one incident a CAB would have prevented." - "You've been here six weeks."

What good looks like. You do not win by citing the standard. You win by finding the version of the control that costs him least: automated policy gates in the pipeline rather than a committee; approval required only for changes touching the payment path; evidence generated by the pipeline itself so nobody fills in a form. Concede the velocity point honestly — because he is right that a CAB would not have prevented NOR-2026-0908, and saying so buys you the credibility to ask for what *would* have.

Fail modes. Appealing to authority ("the auditor requires it"). Getting defensive. Agreeing to something you can't evidence.

Case 4 — The document review (45 min, written)

> "*Here is a risk register. Critique it and tell us what you'd change.*"

Use `03-workbooks/risk-register.xlsx`, `INHERITED-REGISTER`.

Scored on how many structural defects you find and whether you prioritise. Finding twelve problems is good. Saying "the single change with the most leverage is defining the scoring criteria, because without them every other column is opinion" is what gets the offer.

Case 5 — The board presentation (10 min presentation + 10 min questions)

> "*Present your quarterly risk report to the board. You have ten minutes.*"

Build it from your Phase 6 work. Constraints: one page of slides, no more than three. No control names. No framework names except where the board needs them for a decision.

Questions to expect: - "Are we secure?" *(Never yes or no. "Against the threats we've assessed, here's where we sit relative to the appetite you approved, and here are the two places we're outside it.")* - "What keeps you up at night?" *(One specific thing, with a number.)* - "Why should we spend this?" *(Loss avoided vs cost, from your FAIR work.)* - "What happens if we don't?" *(Be concrete. Not "increased risk.")* - Katarína Hoferová, the ex-regulator non-exec, will ask: "*What would our supervisor say if they saw this report?*" Have that answer ready.

Case 6 — The take-home (4 hours, do it in 4)

> "*Perform a gap assessment of Norvela Pay against ISO 27001:2022 and produce a prioritised remediation roadmap with an indicative budget. Maximum 8 pages.*"

This is the most common senior take-home format. Four hours means you cannot assess 93 controls properly, so the real test is **how you triage** — and whether you say so explicitly in the document.

Structure that scores: 1. Approach and limitations (½ page — state what you did not cover and why) 2. Scope and method (½ page) 3. Maturity summary by Annex A theme (1 page, with a visual) 4. Top 10 gaps with business impact (2 pages) 5. Roadmap: 30/90/180/365 days (2 pages) 6. Indicative budget and resourcing (1 page) 7. Assumptions and what you'd validate first (1 page)

What separates good from excellent: section 7. Everyone writes the roadmap. Almost nobody writes the honest list of things they assumed and would check before committing the budget. It is the section that signals you have done this for real.